

Cisco Secure Workload - APRA CPS 234 Compliance Report

Cisco Secure Workload - APRA CPS 234 Compliance Report

Customer-Facing Compliance Report

Framework: APRA Prudential Standard CPS 234 - Information Security

Primary audience: Australian banks, insurers, superannuation trustees, and other APRA-regulated entities; CISO function, technology risk, internal audit, and information asset owners.

CSW positioning: Information asset segmentation, control-implementation evidence, control-testing inputs, incident management, and third-party service-provider visibility.

Framework Version Note

References CPS 234 as published in 2019. Paragraph numbers in this report are well-known and stable for CPS 234; if APRA has issued amendments or related standards in scope (e.g. CPS 230 Operational Risk Management), validate the applicable text.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The reference design (CSW-APRA-CPS234-Technical-Reference design.md) in this folder contains the deeper engineering detail.

How to read the Coverage column

Every report in this set uses the same three coverage words. Coverage describes **what evidence CSW produces** for a topic — it never means the control is passed.

Direct — Secure Workload produces the primary evidence artifact for that topic (segmentation, policy, flow/process telemetry, inventory, vulnerability + reachability, forensic reconstruction). Direct is still evidence, not an attestation.

Supporting — Secure Workload contributes an input that feeds or complements another control, tool, or process (e.g. detection input only, reconciled against an external register, one log source among several).

Evidence Required — Secure Workload has no record for this topic. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

The Coverage ratings in the topic map below are machine-derived from each row's wording and are flagged for SE review before customer use.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW “certifies” compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer’s compliance team, and the customer’s assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does **not** replace the customer’s governance, policy, or assessor judgement, and this report is **not** a control attestation.

Suggested CSW Scope Pattern

CPS-234

- └ Critical-Information-Assets (Customer-Records, Payments-and-Ledger, Trading-Settlement, Policy-and-Claims)
- └ Material-Operations (Online-Channels, Operational-Core)
- └ Service-Providers (Outsourced-Connectivity)
- └ Incident-Evidence

This scope pattern should be validated with the customer’s architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- Para. 20 - Information asset identification and classification
- Para. 21-23 - Implementation of controls (network access layer)
- Para. 24-28 - Incident management (technical scoping)
- Para. 29-33 - Testing of control effectiveness (continuous, not point-in-time)
- Para. 34-35 - Internal audit (evidence pack inputs)

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- Para. 13-15 - Information security capability (governance)
- Para. 16-19 - Policy framework
- Para. 36-37 - APRA notification decision (CSW provides scoping inputs only)
- IAM/PAM, cryptography assurance, BCP/DR, supplier contractual arrangements

Framework Topic → CSW Capability Map

Framework topic	Coverage	CSW capability	Evidence artifact
Para. 20 - Asset identification and	Direct	Workload inventory; scope + label export	Inventory and scope membership export

Framework topic	Coverage	CSW capability	Evidence artifact
classification			reconciled to information asset register
Para. 21-23 - Controls implementation	Direct	Policy workspace; ADM-derived allowlist	Workspace snapshot and observed-vs-approved flow comparison
Para. 21-23 - Third-party paths	Direct	Outbound flow summary to service-provider endpoints	Service-provider egress report
Para. 24-28 - Incident management	Direct	Forensic flow + process telemetry	Investigation pack with timeline and impact scope
Para. 29-33 - Control effectiveness testing	Direct	Continuous flow data; policy-violation log; drift report	Continuous control-testing evidence (replaces point-in-time samples)
Para. 34-35 - Internal audit	Direct	Periodic evidence pack	Quarterly evidence bundle for audit work-papers

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Information asset register reconciliation	Workloads supporting each critical information asset	Inventory + scope membership	Quarterly
Controls-implementation evidence	Workspace snapshot and observed-vs-approved flow comparison	Policy workspace export + ADM export	Quarterly + after each change
Control-effectiveness testing	Continuous policy-violation and drift evidence	Policy analysis output (continuous)	Continuous, reviewed quarterly
Third-party service-provider paths	Outbound flow to vendor endpoints	Flow search filtered to vendor endpoints	Monthly
Incident management	One representative	Flow + process	Per incident; one

Topic	What to collect	CSW source	Suggested cadence
sample	incident timeline	search	representative sample per audit cycle

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. tenant, prototype, isa_level, np1, cui, ephi).
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not replace board accountability for information security (Para. 13-14), the policy framework (Para. 16-19), related-party assurance, IAM/PAM lifecycle, cryptography programme decisions, BCP/DR test outcomes, or the APRA notification decision (Para. 36-37).

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.